

S9L5

ANALISI IOC

CON WIRESHARK



TANCREDI
DE SIMONE

1.Wireshark

1.1 Cos'è un IoC

Per l'esercizio di oggi dovremo analizzare gli IoC (Indicator of Compromise) di uno specifico file .pcap. Gli indicator of compromise sono come delle impronte lasciate da un attaccante verso un sistema o rete. Analizzando gli IoC possiamo ottenere informazioni utili per ricostruire la natura di un attacco capendo da dove è partito, quali sono gli indicatori di rischio e cosa l'attaccante sta provando o è riuscito a fare.

1.2 Cos'è Wireshark

In questo caso stiamo analizzando un attacco subito su una rete, quindi il software scelto per questo sarà Wireshark. Wireshark ci permette di analizzare i protocolli di rete, intercetta i pacchetti inviati tra una rete e l'altra e stila una lista delle interazioni tra le macchine tramite questi pacchetti, dandoti una panoramica precisa del traffico che c'è stato. Il file .pcap che ci è stato dato è appunto una panoramica di scambio tra due reti.

Wireshark permette inoltre di filtrare tra tutte le richieste inviate e ricevute tra le due macchine, funzione molto utile nella Threat Intelligence.

Wireshark ha anche una legenda interna basata sui colori che ci permette al volo visivamente di capire immediatamente la natura di una richiesta inviata o ricevuta, elencherò in questo caso i colori che interessano questo specifico report che dobbiamo analizzare.

Pacchetti TCP con problemi o flag di reset

Indica che la porta che si è provata a raggiungere è chiusa o ha problemi. Oppure, non in questo caso, che la connessione si è interrotta.

Risposte HTTP andate a buon fine

Wireshark usa il verde per il traffico HTTP o, in combinazione con alcune regole per i pacchetti SYN, ACK quando una porta risponde che è aperta a dialogare. Nel contesto dell'attacco capiamo che l'attaccante saprà che le porte che rispondono in questo modo hanno un servizio web attivo.

Traffico Broadcast o protocolli di rete specifici per l'esplorazione delle risorse

Host announcement, nella prima riga vedremo che qui è la macchina Metasploitable che annuncia la sua presenza nella rete locale.

Traffico TCP standard che non ha riscontrato errori immediati

Solitamente tentativi di connessione iniziale SYN.

Risposte TCP andate a buon fine

Risposte di servizi attivi e porte aperte sulla macchina.

Wireshark in questo specifico caso è tutto ciò che ci serve per ricostruire l'attacco su questa rete.

2. Analisi e ricostruzione

2.1 Natura dell'attacco

Possiamo notare, con tutte queste richieste, che l'attaccante ha usato un port scanner, come ad esempio nmap, per fare una classica e massiva Network Reconnaissance.

Nel contesto di un attacco in blackbox spesso la prima cosa che si fa è proprio questo, serve a capire quali porte sono aperte sul target e quali servizi sono attivi. I servizi attivi spesso offrono vettori di attacco, quindi per un attaccante queste possono essere informazioni estremamente utili.

Macchina attaccante: 192.168.200.100

Macchina target: 192.168.200.150 (Metasploitable)

2.2 Dinamica dell'attacco

Analizziamo fase per fase la dinamica dell'attacco per dare un senso alla sfilza di richieste inviate e ricevute. L'attaccante ha scansionato le porte dalla 1 alla 1024.

- **Fase di discovery:** Nelle prima riga possiamo notare l'ip 192.168.200.150 che annuncia la propria presenza sulla rete, successivamente l'attaccante esegue delle richieste ARP query per mappare l'indirizzo MAC della vittima, assicurandosi che l'host effettivamente online
- **Esecuzione dello scan porte target:** L'attaccante con queste richieste cicla una sfilza di porte, in questo caso fino alla porta 1024, un attacco molto aggressivo e non mirato a porte specifiche, visto che probabilmente l'attaccante non sa nulla della macchina target, motivo per cui ha un range di porte così alto.
- **Risposte della vittima:** Più avanti nella lista possiamo notare una sfilza di pacchetti rossi, in questo caso è la macchina target che sta rispondendo che quei servizi e quelle porte sono chiuse. Abbiamo poi le risposte in cui le porte sono aperte evidenziate in verde chiaro e grigio chiaro.

Comando probabilmente utilizzato: `nmap -sT -p 1-1024 192.168.200.150`

Dove -sT sta per uno scan completo three way handshake. E con specificato il range di porte con -p seguito dall'ip della vittima.

Porte Aperte

Utilizzando un filtro su wireshark possiamo immediatamente vedere quali porte sono aperte sul target, e quindi quali informazioni il nostro attaccante ha in mano.

Ho impostato il filtro `tcp.flags.syn == 0 && tcp.flags.ack && tcp.flags.reset == 0`

Il filtro isola soltanto le richieste in cui c'è la ricevuta di ritorno ACK dicendoci quindi solo le porte aperte

Con questo filtro abbiamo le porte aperte:

tcp.flags.syn == 0 && tcp.flags.ack && tcp.flags.reset == 0SSSSSs									
No.	Time	Source	Destination	Protocol	Length	Info			
6	23.764815289	192.168.200.100	192.168.200.150	TCP	66	53060	-- 80	[ACK]	Seq=1 Ack=1 Win=64256 Len=0 TSval=810522428 TSecr=4294951105
24	36.774709464	192.168.200.100	192.168.200.150	TCP	66	41304	-- 23	[ACK]	Seq=1 Ack=1 Win=64256 Len=0 TSval=810535438 TSecr=4294952466
25	36.774711072	192.168.200.100	192.168.200.150	TCP	66	56120	-- 111	[ACK]	Seq=1 Ack=1 Win=64256 Len=0 TSval=810535438 TSecr=4294952466
28	36.775174048	192.168.200.100	192.168.200.150	TCP	66	41182	-- 21	[ACK]	Seq=1 Ack=1 Win=64256 Len=0 TSval=810535438 TSecr=4294952466
37	36.775893786	192.168.200.100	192.168.200.150	TCP	66	55656	-- 22	[ACK]	Seq=1 Ack=1 Win=64256 Len=0 TSval=810535439 TSecr=4294952466
38	36.775813232	192.168.200.100	192.168.200.150	TCP	66	53062	-- 80	[ACK]	Seq=1 Ack=1 Win=64256 Len=0 TSval=810535439 TSecr=4294952466
65	36.776914772	192.168.200.100	192.168.200.150	TCP	66	33042	-- 445	[ACK]	Seq=1 Ack=1 Win=64256 Len=0 TSval=810535440 TSecr=4294952466
66	36.776941020	192.168.200.100	192.168.200.150	TCP	66	46990	-- 139	[ACK]	Seq=1 Ack=1 Win=64256 Len=0 TSval=810535440 TSecr=4294952466
67	36.776962320	192.168.200.100	192.168.200.150	TCP	66	60632	-- 25	[ACK]	Seq=1 Ack=1 Win=64256 Len=0 TSval=810535440 TSecr=4294952466
68	36.776983878	192.168.200.100	192.168.200.150	TCP	66	37282	-- 53	[ACK]	Seq=1 Ack=1 Win=64256 Len=0 TSval=810535440 TSecr=4294952466
165	36.781512468	192.168.200.100	192.168.200.150	TCP	66	45648	-- 512	[ACK]	Seq=1 Ack=1 Win=64256 Len=0 TSval=810535445 TSecr=4294952466
268	36.788833247	192.168.200.100	192.168.200.150	TCP	66	51396	-- 514	[ACK]	Seq=1 Ack=1 Win=64256 Len=0 TSval=810535452 TSecr=4294952467
997	36.825733008	192.168.200.100	192.168.200.150	TCP	66	42048	-- 513	[ACK]	Seq=1 Ack=1 Win=64256 Len=0 TSval=810535489 TSecr=4294952471

21: FTP File Transfer Protocol

22: SSH Secure Shell

23: Telnet

25: SMPT Simple Mail Transfer Protocol

53: DNS Domain Name Server

80: HTTP HyperText Transfer Protocol

111: RCPbind Portmap

139: NetBIOS-SSN

445: SMB Server Message Block

512: Rexec Remote Execution

513: Rlogin Remote Login

514: Rsh Remote Shell

Conoscendo i servizi target aperti e potenzialmente vulnerabili possiamo attuare un preciso piano di mitigazione proprio per questi servizi oltre a delle best practice di sicurezza.

3. Vettori di attacco e Mitigazione

3.1 Potenziali vettori di attacco

Ora, noi sappiamo che Metasploitable è progettata per essere vulnerabile appositamente, quindi abbiamo alcuni possibili vettori per continuare l'attacco una volta che l'attaccante ha ricevuto le informazioni sui servizi aperti con questo port scanner.

Porta 80 Web Application

Strumenti come GoBuster possono aiutare un potenziale attaccante a mappare l'applicazione web e eseguire un'enumerazione delle directory, nonché poter cercare istanze php vulnerabili. Con metodi di SQL injection potrebbe poi esfiltrare il database della macchina target.

Porta 21 FTP

Il servizio FTP su Metasploitable ha una versione 2.3.4 con una backdoor volutamente inserita che l'attaccante può sfruttare per ottenere una shell di comando sulla porta 6200

Porta 22 SSH

Qui sono ovviamente possibili attacchi di bruteforce, inoltre Metasploitable ha una nota vulnerabilità OpenSSL, CVE-2008-0166 nel servizio.

Porta 23 Telnet Brute forcing e credenziali di Default

Telnet è un servizio obsoleto che trasmette tutto in chiaro, anche le password, utilizzando un tool come Hydra un potenziale attaccante potrebbe eseguire un attacco a dizionario con alcune password di default per ottenere una shell con privilegi amministrativi.

Porte 139/445 RCE e lateral movement

Queste porte gestiscono la condivisione in rete di file e stampanti, su Linux si tratta di Samba che è servizio notoriamente vulnerabile ad alcuni exploit conosciuti come SambaCry. Anche in questo caso l'attaccante non dovrebbe avere troppi problemi a stabilire una sessione con privilegi Root.

Porta 25 SMTP Enumerazione utenti

Il protocollo Simple Mail Transfer Protocol può essere interrogato con comandi legacy come VRFY (Verify) o EXPN (Expand) inviando una lista di nomi utente comuni. Il server può rispondere confermando o meno la presenza di un utente della lista sulla macchina, a quel punto un eventuale brute forcing diventa molto molto più semplice.

Ci sono sicuramente altri metodi di attaccare la macchina, mi sono concentrato sui metodi che abbiamo visto a lezione e che sarei in grado personalmente di sfruttare.

3.2 Mitigazione

Ora passiamo a come mitigare l'attacco ricevuto o a come prevenire attacchi futuri.

Mitigazioni Generali

Per prima cosa, prima di andare nello specifico sui servizi vulnerabili, possiamo pensare ad alcune soluzioni generali per ridurre una possibilità di attacco.

- **Implementare un Firewall:** Sicuramente l'implementazione di un firewall con regole specifiche è un'ottima soluzione per i problemi di vulnerabilità della macchina. Impostando un firewall possiamo impostare le porte chiuse su "DROP" anziché "REJECT", in questa maniera le richieste dell'attaccante invece di avere una risposta negativa, confermando che le porte sono chiuse, non riceveranno proprio risposta, aumentando notevolmente il tempo di scansione e non facendo capire all'attaccante se una porta è aperta o meno. Ovviamente questa strategia serve a prevenire attacchi futuri dato che in questo caso il nostro attaccante sa già quali porte sono aperte.
- **Cambiare le porte di Default:** Per i servizi vulnerabili possiamo cambiare le porte di Default non permettendo all'attaccante di sfruttare le informazioni che ha ottenuto. Questo in combinazione con la regola firewall precedente, impedirà all'attaccante di sapere su quali porte abbiamo spostato i nostri servizi.
- **Configurazione servizi:** Possiamo inoltre, nel caso l'attaccante riuscisse comunque a trovare le nuove porte non di default configurate, fare in modo che i nostri servizi non rivelino la loro versione. A quel punto un potenziale attaccante dovrà andare alla cieca.

Mitigazioni Specifiche

Porta 21 FTP

Come già specificato la versione di vsftpd ha una backdoor intenzionale, in questo caso basterà aggiornare la versione, per poi impedire l'accesso con l'utente Anonymous che viene utilizzato per accedere al servizio senza conoscere una Password utente

Porta 22 SSH

Disabilitare l'accesso tramite password e impostare solo l'accesso tramite chiavi SSH robuste come RSA.

Porta 23 Telnet

Rimuovere completamente il servizio, è estremamente obsoleto e costituisce un rischio alla sicurezza troppo grande per essere tenuto.

Porta 25 SMTP

Disattivare i comandi VRFY inserendo la direttiva `disable_vrfy_command = yes` in maniera tale da impedire all'attaccante di enumerare gli utenti.

Porta 80 HTTP

Essendo su una Metasploitable ha logicamente delle applicazioni web appositamente vulnerabili, la cosa più logica da fare sarebbe rimuoverle del tutto, nel caso non si volesse allora si potrebbe innanzitutto inserire una sanificazione dell'input nelle caselle dove è possibile tentare un'SQL injection, e poi nascondere la versione di Apache.

Porta 139 e 445 SMB e NetBIOS

Aggiornare Samba all'ultima versione disponibile. Applicare restrizioni agli host escludendo l'ip della macchina attaccante.